SSH Server Configuration Audit — OpenSSH `sshd_config`

Date: 2026-10-31 (audit carried out 2026-10-29) · **Prepared by:** security analyst · **Input:** `examples/ornek-sshd_config` — an OpenSSH `sshd_config` file of 16 lines, 15 of them active directives

Summary

- 8 baseline hardening items were checked. 1 passed and 7 failed (1 + 7 = 8). Alongside the checklist, 8 additional hardening findings plus one logging recommendation were recorded; these are reported separately and are **not** part of the 8-item count.
- Most urgent finding, Critical: `PermitEmptyPasswords yes` (line 6) allows accounts with an empty password to log in over SSH.
- Do this first: set `PermitEmptyPasswords no` and `PermitRootLogin no`, then move authentication to keys only — note that turning off `PasswordAuthentication` alone is not enough on this file, because `UsePAM yes` is active and there is no `KbdInteractiveAuthentication` line, so passwords would still be requested through the keyboard-interactive path.
- Every **FACT** below points to an exact line of the file you sent, or to a search showing a setting is absent.

Labels: `FACT` = read directly from your file · `FIX` = recommended change · `CHECK` = depends on your software version; confirm before applying.

Scope

- Input: `examples/ornek-sshd_config` — a synthetic portfolio sample, not a real customer server. 16 lines in total, 15 active directives. Comment lines beginning with `#` were not counted as active settings. Line numbers in this document are the file's real line numbers.
- Checklist: OpenSSH baseline hardening, 8 items. Counting rule: passed + failed = items applied (8). Passed: 1 · Failed: 7.
- Also reported, outside the 8-item checklist: encryption (`Ciphers`) and MAC algorithms, dead-connection detection / idle timeout, forwarding, obsolete directives and connection limits. These appear under "Additional hardening findings" — 8 findings plus one logging recommendation — and are deliberately excluded from the 8-item count.
- Out of scope: the file was not modified. No service restart, no firewall change and no access to a live server took place. The OpenSSH version running on the server was not part of what you sent.

Findings

Ordered by severity, highest first.

Baseline checklist — 8 items (1 passed, 7 failed)

#	Severity	Setting (line)	FACT	FIX
1	Critical	`PermitEmptyPasswords yes` (line 6)	Accounts with an empty password are allowed to open a session; this is a critical risk. Expected: `no`.	`PermitEmptyPasswords no`
2	High	`PermitRootLogin yes` (line 4)	The `root` account may log in directly over SSH. Expected: `no` (or `prohibit-password`).	`PermitRootLogin no`; carry out administration through a user account with `sudo`.

#	Severity	Setting (line)	FACT	FIX
3	High	`PasswordAuthentication yes` (line 5)	Password authentication is enabled, which raises the risk from brute-force attempts and from leaked passwords. Expected: `no`. In addition, `UsePAM yes` is active (line 14) and there is no `KbdInteractiveAuthentication` line (default: `yes`), so even with `PasswordAuthentication no` a password would still be requested through the PAM keyboard-interactive method.	`PasswordAuthentication no` plus a new `KbdInteractiveAuthentication no` line (on OpenSSH releases before 8.7 the equivalent is `ChallengeResponseAuthentication no`), leaving public-key authentication as the only method.
4	Medium	`MaxAuthTries 10` (line 9)	10 attempts per connection makes brute-force attempts easier. Expected: 3–4.	Lower it to `MaxAuthTries 3` (or 4).
5	Medium	`AllowUsers` / `AllowGroups` not defined (search result: 0 matches)	Neither directive appears anywhere in the file, so SSH access is not restricted to specific users or groups. Expected: defined.	Add an `AllowUsers` or `AllowGroups` directive listing only authorised accounts (for example `AllowGroups ssh-users`).
6	Medium	`X11Forwarding yes` (line 8)	X11 forwarding is enabled, which widens the attack surface if it is not needed on the server. Expected: `no`.	`X11Forwarding no`
7	Low	`LoginGraceTime 120` (line 10)	The 120 seconds allowed for authentication can let half-open connections accumulate and consume resources. Expected: 60 seconds or less.	`LoginGraceTime 30` (or any value up to 60).
8	Passed	`PubkeyAuthentication yes` (line 7)	Public-key authentication is enabled; this matches the checklist (expected: `yes`).	None — no change needed.

Additional hardening findings (outside the 8-item checklist)

Eight findings, plus one logging recommendation (row 16).

#	Severity	Setting (line)	FACT	FIX
9	High	`Ciphers aes128-cbc,3des-cbc,aes256-cbc` (line 15)	Only CBC-mode ciphers are offered. `3des-cbc` is weak and CBC modes carry known weaknesses (for example plaintext recovery). No AEAD or CTR cipher is offered.	Move to strong AEAD/CTR ciphers: `Ciphers chacha20-poly1305@openssh.com,aes256-gcm@openssh.com,aes128-gcm@openssh.com,aes256-ctr,aes192-ctr,aes128-ctr`. See the Terrapin note below.
10	High	`MACs hmac-md5,hmac-sha1` (line 16)	`hmac-md5` is weak, `hmac-sha1` is outdated (SHA-1), and neither is an encrypt-then-MAC (ETM) algorithm.	Move to SHA-2 ETM MACs: `MACs hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.com,umac-128-etm@openssh.com`. See the Terrapin note below.
11	Medium	`AllowTcpForwarding yes` (line 12)	TCP forwarding is enabled, which widens	`AllowTcpForwarding no` if you do not need it.

#	Severity	Setting (line)	FACT	FIX
			the surface for lateral movement (pivoting) if the host is not used as a bastion or jump server.	
12	Medium	`AllowAgentForwarding` line absent (search result: 0 matches; default `yes`)	SSH agent forwarding is therefore enabled. On a compromised server, a forwarded agent socket can be abused.	Add `AllowAgentForwarding no` if you do not need it.
13	Low	`ClientAliveInterval 0` (line 11)	The server sends no liveness probe to clients, so unresponsive (dropped or dead) client connections are not detected at the SSH layer. Note: this setting is not an idle timeout — an idle but connected client answers the probes and its session stays open.	For dead-connection detection, change `ClientAliveInterval 0` to `ClientAliveInterval 300` and add `ClientAliveCountMax 2`. For a genuine idle-session timeout (OpenSSH 9.2 and later) use `ChannelTimeout session=15m` and `UnusedConnectionTimeout 15m`; the durations should be set to match your own policy.
14	Low	`MaxStartups` and `MaxSessions` lines absent (search result: 0 matches)	The defaults therefore apply: `MaxStartups 10:30:100` and `MaxSessions 10`.	To limit concurrent unauthenticated connections set `MaxStartups 10:30:60`, and to cap the sessions per connection set `MaxSessions` as needed (for example 2–4).
15	Info	`Protocol 2` (line 3)	This directive has been obsolete since OpenSSH 7.4 and is ignored by sshd; SSH-1 support has been removed. The line is harmless but misleading.	Remove the `Protocol 2` line.
16	Info	`LogLevel INFO` (line 13)	This is the log level set in the file.	Using `LogLevel VERBOSE` instead strengthens auditing, because it records the key fingerprints used to log in.
17	Info	`Port 22` (line 2)	The standard SSH port is in use. The risk impact of changing the port (less automated scanning noise) is a matter of organisational preference; it is not a security measure on its own.	No change is put forward for this item.

Terrapin note (CVE-2023-48795): `chacha20-poly1305` and the `*-etm` MACs are only safe with strict key exchange, which requires OpenSSH 9.6 or later (or an equivalent client that supports strict key exchange) on **both** sides. Update the server and its clients accordingly.

Point that could not be determined from what you sent

- CHECK — The server's OpenSSH version was not part of the input. Before applying the version-dependent recommendations above — the `KbdInteractiveAuthentication` directive name (OpenSSH 8.7 and later),

`ChannelTimeout` and `UnusedConnectionTimeout` (9.2 and later), and strict key exchange (9.6 and later) — confirm the version with `sshd -V` and test the configuration with `sshd -t`.

Consolidated changes

Every line below is taken from the **FIX** column above; nothing new is introduced.

```
PermitEmptyPasswords no
PermitRootLogin no
PasswordAuthentication no
KbdInteractiveAuthentication no      # OpenSSH 8.7+; before that: ChallengeResponseAuthentication no
MaxAuthTries 3
AllowGroups ssh-users                # list only your own authorised accounts
X11Forwarding no
LoginGraceTime 30
AllowTcpForwarding no                # if you do not need it
AllowAgentForwarding no              # if you do not need it
ClientAliveInterval 300
ClientAliveCountMax 2
ChannelTimeout session=15m           # OpenSSH 9.2+; duration per your own policy
UnusedConnectionTimeout 15m          # OpenSSH 9.2+; duration per your own policy
MaxStartups 10:30:60
MaxSessions 4                        # 2-4, as needed
LogLevel VERBOSE
Ciphers chacha20-poly1305@openssh.com,aes256-gcm@openssh.com,aes128-gcm@openssh.com,aes256-ctr,aes192-ct
r,aes128-ctr
MACs hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.com,umac-128-etm@openssh.com
# remove the obsolete line: Protocol 2
# PubkeyAuthentication yes is already correct and is left as it is
```

Before applying: confirm your OpenSSH version with `sshd -V` and test the configuration with `sshd -t`. The version matters for the `KbdInteractiveAuthentication` line (OpenSSH 8.7 and later), for the `ChannelTimeout` and `UnusedConnectionTimeout` lines (9.2 and later), and for the strict key exchange that the new `Ciphers` and `MACs` lines rely on (9.6 and later, on both server and clients).

Evidence

Source lines (`examples/ornek-sshd_config:<line>`):

- `2` — `Port 22`
- `3` — `Protocol 2`
- `4` — `PermitRootLogin yes`
- `5` — `PasswordAuthentication yes`
- `6` — `PermitEmptyPasswords yes`
- `7` — `PubkeyAuthentication yes`
- `8` — `X11Forwarding yes`
- `9` — `MaxAuthTries 10`
- `10` — `LoginGraceTime 120`
- `11` — `ClientAliveInterval 0`
- `12` — `AllowTcpForwarding yes`
- `13` — `LogLevel INFO`
- `14` — `UsePAM yes`
- `15` — `Ciphers aes128-cbc,3des-cbc,aes256-cbc`

- `16` — `MACs hmac-md5,hmac-sha1`

Absent settings (command → output):

- `grep -ciE '^\s*allow(users|groups)' examples/ornek-sshd_config` → `0`
- `grep -ciE '^\s*KbdInteractiveAuthentication' examples/ornek-sshd_config` → `0`
- `grep -ciE '^\s*ChallengeResponseAuthentication' examples/ornek-sshd_config` → `0`
- `grep -ciE '^\s*ClientAliveCountMax' examples/ornek-sshd_config` → `0`
- `grep -ciE '^\s*(ChannelTimeout|UnusedConnectionTimeout)' examples/ornek-sshd_config` → `0`
- `grep -ciE '^\s*AllowAgentForwarding' examples/ornek-sshd_config` → `0`
- `grep -ciE '^\s*(MaxStartups|MaxSessions)' examples/ornek-sshd_config` → `0`

File size:

- `wc -l examples/ornek-sshd_config` → `16`
- `grep -cvE '^\s*(#|$)' examples/ornek-sshd_config` → `15` (active lines)

Verification

Every **FACT** in this document rests on a line quoted word for word from the file you sent, or on one of the search outputs shown above; no number was estimated. The counts are consistent: 1 passed item plus 7 failed items make up the 8-item baseline checklist, and the 8 additional hardening findings plus one logging recommendation are reported separately and are not included in that count. The file has 16 lines of which 15 are active directives. The recommendations that depend on your OpenSSH version are marked **CHECK** rather than presented as settled, because the version was not part of the input and must be confirmed with `sshd -V` and `sshd -t` first. An independent second review re-checked all facts, numbers and severity ratings against the source file before delivery.